Post-Breach Information Security & Cyber Resilience Policy:

Corporate Governance Mandate for People, Process, and Technology Realignment Post-Incident

Meta data attributes	Classification & ownership details
Organization:	Company X (Undisclosed name subject to non-disclosure agreement)
Policy Owner:	Jacques Bruges / Chief Information Security Officer
Architecture Authority:	Frederic Belinga / Sr Security Architect
Framework Mapping	NIST SP 800-207 (Identify, Protect, Detect, Respond, Recover)
Regulatory Alignments	FINMA BCM Guidelines, Swiss nFADP, DORA (Article 6)
Classification	Internal / Highly Confidential
Review cycle	Annual and mandatory out-of-cycle review following high-impact security incidents
Document Version	Post-Breach Remediation Lifecycle
Nature of attack	Executive Credential Hijacking & Control Plane Take over Privilege Escalation.

1. Purpose

This policy establishes mandatory corporate cybersecurity requirements to remediate infrastructure vulnerabilities and protect Company X's information systems, multi-cloud ecosystems, users, applications, and core data stores following the historical security breach. Rather than assessing individual technical controls in isolation, this policy mandates a holistic, risk-based approach to enterprise security governance. It establishes an integrated security program based on the NIST Cybersecurity Framework functions of **Identify, Protect, Detect, Respond and Recover**.

Its objectives are to:

- **Breach Impact Isolation:** Minimize the blast radius, likelihood, and operational impact of future enterprise security breaches.
- **Consistent Controls:** Standardize and enforce homogeneous security controls across all on-premises, AWS, and Azure environments.
- **Enhanced Monitoring:** Accelerate real-time security-event detection, tactical threat hunting, and automated incident response capabilities.
- **Identity & Workload Safeguards:** Protect enterprise identities, cloud workloads, network perimeters, and sensitive information repositories.
- **Measurable Governance:** Establish definitive security governance metrics, clear accountability, and audit-ready compliance pathways.
- **Resilience & Recovery:** Build robust, highly available cyber resilience models and rapid cross-cloud disaster recovery pipelines.
- **Zero Trust Enforcement:** Eliminate legacy implicit trust models through the strict institutionalization of NIST SP 800-207 Zero Trust and Least Privilege architecture baselines.

2. Scope

Compliance with this policy is non-negotiable and strictly mandatory across all business units unless a formal, risk-justified policy exception has been officially approved by the CISO. The provisions of this mandate apply universally to the following organizational dimensions: all employees, contractors, consultants and authorized third parties.

Assets & Infrastructure

- **Applications & Workloads:** All software deployments, microservices, containerized assets, and cloud-native workloads.

- **Backup & Disaster Recovery:** All offsite replication nodes, immutable data backups, and standby recovery environments.

- **Databases & Storage:** All data-at-rest repositories, data lakes, file shares, and structured databases.

- **Endpoints & Servers:** All corporate laptops, mobile devices, on-premises physical hardware, and cloud virtual machines.
- **Networks & Firewalls:** All software-defined networking, cloud VPCs/VNets, border firewalls, and cryptographic perimeters.
- **On-Premises Infrastructure:** All remaining legacy data centers, local servers, and local network routing components.
- **Security Monitoring Platforms:** All data ingestion hubs, log archives, EDR/XDR components, and central SIEM/SOAR/UBA workspaces.

Identities & Access

- **Corporate Identities:** All standard employee, contractor, consultant, and temporary workforce digital identities.
- **Privileged Accounts:** All administrative, root, service account, and high-clearance cryptographic credentials.
- **Third-Party Connections:** All vendor API access points, external supply-chain links, and federated business partner connections.

Compliance with this policy is mandatory unless a formally documented exception has been approved.

3. Roles & Responsibilities

- Executive Management: Will establish institutional cyber risk appetite and risk tolerance boundaries. Will ensure cyber risk profiles are explicitly evaluated during all corporate strategic decisions and board reviews. Will guarantee appropriate financial and human resource allocations to sustain the enterprise security program.

- CISO / Security Management: Will maintain complete ownership of the enterprise cybersecurity and risk governance program. Will orchestrate regular risk posture reporting and security performance metrics to Executive Leadership and the Board. Will review, authorize, and track all high-risk policy exceptions and compliance variances.

- Senior Security Architect:

- **Will assess Trade-offs:** Evaluate architectural trade-offs, engineering limitations, and business requirements to optimize design selections.
- **Define Patterns:** Author and publish standardized security design patterns, approved reference architectures, and mandatory controls.
- **Direct Teams:** Provide authoritative technical direction, architectural guardrails, and secure coding/deployment requirements to engineering teams.
- **Ensure Interoperability:** Validate technical interoperability and telemetry synchronization between disparate multi-vendor security tools (e.g., Sentinel, Defender, Okta, Ansible).
- **Establish Zero Trust:** Architect the transition to a NIST SP 800-207 Zero Trust framework, enforcing strict JIT, ABAC, and micro-segmentation models.
- **Lead Reviews:** Chair formal architecture and security design reviews for all incoming technology implementations.
- **Review Exceptions:** Audit and provide technical risk evaluations for all requested material architecture policy exceptions.
- **Set Target State:** Define, maintain, and own the multi-cloud target-state security architecture blueprint.
- **Translate Requirements:** Translate complex business, financial, and regulatory risk obligations into concrete technical architecture requirements.
- **Validate Alignment:** Perform post-implementation audits to validate that deployed engineering solutions match approved security blueprints.

- Engineering / Operations Team: Will implement and build technical solutions that strictly adhere to approved security architecture requirements and design patterns. Maintain catalog and provide technical artifacts and configuration evidence to demonstrate ongoing policy compliance during audits. Remediate identified security misconfigurations and software vulnerabilities within mandated patching windows.

- SOC (Security Operation Center): Shall continuously monitor security events, investigate alerts, escalate suspected incidents and coordinate response activities. Execute continuous, 24/7/365 security event monitoring and alert triage across the entire enterprise data lake. Investigate behaviors anomalies, hunt proactively for hidden threats, and rapidly escalate confirmed security incidents. Orchestrate and coordinate localized and global response activities using automated SOAR playbooks.

- Users (Employees & third parties' stakeholders)

Users shall comply with access-control, authentication, data-protection and acceptable-use requirements and promptly report suspected security events. Adhere strictly to corporate identity verification, authentication, data handling, and acceptable use guidelines. Will report suspected security anomalies, phishing vectors, or compromised system behaviors to the SOC without delay.

4. IDENTIFY — Understand Cybersecurity Risk

Company X shall maintain absolute, continuous visibility across its asset landscape, vulnerabilities, threat vectors, business dependencies, and enterprise risks. Following the historical security incident, a comprehensive security gap and vulnerability assessment shall be immediately mandated to establish the remediation baseline. This establishes total asset visibility and risk quantification to ensure a data breach can never catch Company X off guard again.

4.1 Asset Management

Company X shall enforce the continuous discovery and maintenance of real-time inventories across all operational environments. At a minimum, inventories must dynamically catalogue:

- **Identities:** Active corporate users, third-party contractors, and highly privileged service credentials.
- **Infrastructure:** Physical/virtual servers, cloud workloads (EC2, Virtual Machines), containerized microservices, and user endpoints.
- **Network & Data:** Corporate databases, SaaS storage volumes, software-defined network perimeters, and active security appliances.
- **Ecosystem:** Dynamic AWS/Azure resource registers and external third-party API connection links.

Governance Mandate: Every identified enterprise asset **shall be assigned a designated Business Owner and Technical Owner** held strictly accountable for its security posture.

4.2 Data Classification and sensitivity matrix

Information must be classified based on data sensitivity, financial impact, and regulatory liability (**nFADP/GDPR**). Data protections and encryption mandates shall escalate linearly according to this hierarchy

At minimum: **Public** (Low risk) → **Internal** (Internal only) → **Confidential** (Regulated PII) → **Restricted** (Highly sensitive)

Tiers:

Public = Unrestricted access; standard integrity verifications applied.

Internal = Standard access controls; restricted to authenticated internal identities.

Confidential = Enforces At-Rest & In-Transit Encryption; strict compliance auditing for customer PII.

Restricted = Hard Micro-segmentation required; hardware-backed MFA, and continuous session auditing.

4.3 Risk Assessment

Continuous threat modeling, automated vulnerability assessments, and formal architecture reviews shall be executed systematically across the entire **Zero Trust Domain Architecture**: **IAM → Network → Workloads → Data → Monitoring → Incident Response → Disaster Recovery**

All identified security deficiencies shall be prioritized, tracked, and managed within a centralized **Enterprise Corporate Risk Register** structured with the following metadata columns:

Asset Class → Threat vector→ Vulnerability → Likelihood → Business Impact → Risk Rating → Compensating Control → Owner → Treatment strategy → Remediation Due Date

Remediation Mandate: Any risk rated as **Critical** or **High** shall bypass standard maintenance cycles and receive immediate, out-of-band remediation.

4.4 Vulnerability Management

All systems must undergo automated, periodic configuration scanning and vulnerability assessment powered by the **Tenable** ecosystem. Discovered vulnerabilities shall be remediated according to strict, non-negotiable **Service Level Agreements (SLAs)** based on Common Vulnerability Scoring System (CVSS) metrics:

Vulnerability Severity Tier	Technical Definition (CVSS v3/v4 Score)	Remediation SLA Target
Critical	9.0 −10.0	**Within 48 Hours**
High	7.0 −8.9	**Within 14 Days**
Medium	4.0 −6.9	**Within 30 Days**
Low	0.1 −3.9	**Scheduled maintenance window**

Exception Protocol: Any variance from these timelines requires a formally documented **Risk Acceptance Request**, evaluated by the **Senior Security Architect**, and officially signed off by the CISO.

5. PROTECT — Implement Preventive Controls

Security controls shall follow **Zero Trust, Least Privilege and Defense-in-Depth** principles.

5.1 Identity & Access Management

Access shall be based on verified identity and legitimate business requirements. The organization shall implement a unified security fabric that enforces identity governance seamlessly across its hybrid multi-cloud infrastructure (**AWS and Azure**).

Company X shall implement and strictly enforce the following to limit lateral movement and mitigate privilege escalation:

- **Centralized IAM**: All corporate and cloud identities must be managed from a singular, unified identity plane. This directly remediates fractured regional silos, eliminating identity fragmentation across cloud environments.

- **Multi-Factor Authentication (MFA)**: Mandatory enforcement of context-aware, phishing-resistant MFA across all authentication vectors.

- **RBAC / ABAC Frameworks**: Role-Based Access Control (RBAC) and Attribute-Based Access Control (ABAC) must be dynamically applied. Access policies must continuously evaluate live telemetry—including user identity, machine health (MDM/EDR), location, and data sensitivity—before granting access.

- **Privileged Access Management (PAM)**: Deploy an explicit **Zero Trust PAM** model utilizing dynamic session brokering and a dedicated control plane. Persistent administrative accounts are prohibited; elevated rights must utilize **Just-In-Time (JIT)** and Just-Enough-Access (JEA) activation mechanisms to restrict standing privileges.

- **Separation of Duties (SoD)**: Operational roles, administrative privileges, and security monitoring tasks must be strictly segregated to minimize malicious insider risks and single points of failure.

- **Periodic Access Reviews**: Routine entitlement audits and access certifications must occur on a continuous, mandated cadence to identify and reverse gradual privilege creep.

- **Automated Deprovisioning**: Lifecycle triggers must immediately isolate or terminate inactive, transferred, or offboarded user accounts to avoid unauthorized stale credential exposure.

- **Contextual Access**: Conditional access policies must dynamically validate device compliance, behavioral anomalies, and operational needs in real time at the trust-zone boundary.

5.1.1 Privileged Account Enforcement & Auditing

- 100% Protection Mandate: Exactly 100% of privileged accounts (inclusive of cloud control planes, identity systems, and root-level infrastructure) must be secured by MFA and strict PAM architecture.
- Individual Attribution: Every single privileged action, command execution, and configuration change must be uniquely attributable to a verified individual identity. Continuous session logging, auditing, and threat behavioral analytics must feed directly into Microsoft Sentinel.
- Shared Account Prohibition: The use of shared or generic privileged accounts is strictly prohibited. Exceptions are permitted only if technically unavoidable, and they require formal, documented architectural sign-off alongside emergency break-glass procedures.

5.1.2 Regulatory Alignment Reference

These identity controls serve as the mandatory preventive foundation to achieve structural compliance with FINMA operational resilience standards, Swiss nFADP / GDPR data protection rules for Customer Identifiable Information (PII), and DORA frameworks for mitigating severe ICT disruptions.

5.2 Network Security

Network architecture shall enforce strict segmentation between security zones to eliminate implicit trust models and prevent threat lateral movement.

5.2.1 Core Network Controls

To resolve the structural vulnerabilities of legacy infrastructure and eliminate fractured regional visibility, the enterprise network fabric across our hybrid multi-cloud environment (AWS and Azure) shall implement:

- **Next-Generation Firewalls (NGFW)**: Deployment of advanced, application-aware filtering at perimeter boundaries and cloud transit zones to enforce deep packet inspection.
- **IDS / IPS**: Continuous, multi-cloud automated Intrusion Detection and Prevention Systems to monitor network payloads and intercept known and emerging exploit signatures in real time.
- **Demilitarized Zones (DMZ)**: Isolated network segments to host public-facing services, ensuring zero direct external connectivity to backend systems or transaction environments.
- **Network Segmentation**: Macro-level zoning to decouple corporate IT, development environments, and production systems across all physical and cloud regions.
- **Micro-Segmentation**: Workload-level isolation inside AWS and Azure. Every individual host, container, and virtual instance must reside within a micro-segmented trust zone to limit the blast radius of any potential compromise and stop ransomware encryption.
- **Secure Remote Access**: Elimination of legacy VPN architectures in favour of continuous, cryptographically verified remote entry vectors that evaluate live device compliance.
- **Zero Trust Network Access (ZTNA)**: Application of **NIST SP 800-207** ZTNA principles. Network placement no longer grants access; all connectivity requests must undergo context-aware verification prior to session brokering.
- **Secure Access Service Edge (SASE)**: Convergence of network security functions—such as SWG and cloud firewalls—into a unified cloud-native platform to secure distributed regional access points.
- **Cloud Access Security Broker (CASB)**: In-line and API-based CASB enforcement to govern data transit, detect shadow IT, and enforce data loss prevention policies between cloud tenants.
- **SD-WAN Security Controls**: Integrated encryption, traffic shaping, and unified threat management across software-defined wide area network paths linking regional offices to cloud hubs.

5.2.2 Zero Trust Network Flows & Architecture Mandates

- **Deny-by-Default Core Principle**: All network flows between trust zones, subnets, and individual workloads shall follow a strict deny-by-default and explicitly authorized model. Any traffic that is not explicitly defined by an approved business application rule is blocked automatically.

- **Cross-Cloud Telemetry Synchronization**: All network flow logs, firewalls, and ZTNA connection telemetry must stream in real time into Microsoft Sentinel (SIEM/SOAR). Local cloud network incidents must instantly trigger AWS SSM**,** AWS Lambda**, and** Ansible playbooks to dynamically isolate non-compliant nodes and modify network security rules within seconds.

- **Regulatory Resilience**: These network protection metrics are structurally required to satisfy FINMA business continuity mandates, DORA digital operational resilience frameworks for high-velocity transaction protection, and Swiss nFADP / GDPR data isolation controls for client PII.

5.4 Data Protection

Sensitive data shall be protected throughout its lifecycle to prevent data exfiltration and ensure Swiss nFADP and GDPR compliance for client PII.

- **Encryption Mandates**: Exactly 100% of critical workloads shall undergo cryptographic assessment. Sensitive information must be encrypted at rest (AES-256) and in transit (TLS 1.3). High-risk financial transaction pipelines must use advanced protection (e.g., secure enclaves) during processing.

- **Key Governance & DLP**: Encryption keys must be centrally managed and rotated via approved cloud capabilities (AWS KMS / Azure Key Vault). In-line and API-based DLP controls shall actively block high-risk information flows and shadow IT.

5.5 Cloud Security

All deployments across AWS and Azure must conform to approved, cloud-agnostic architecture patterns to ensure multi-cloud resilience.

- **Security Architecture Review**: No resource shall be deployed outside approved governance boundaries. All deployments must undergo a formal review covering:

Identity →Network →Data →workloads → loggings → Resilience → Compliance

Resilience & Enforcement: Cloud infrastructure must utilize automated cross-cloud redundancy to satisfy FINMA and DORA metrics (RTO/RPO). Non-compliant or drifting resources must be autonomously isolated or remediated within seconds via AWS SSM, Lambda, and Ansible.

5.5 Cloud Security

Vendors (AWS and Azure) resources shall conform to approved cloud-security architecture patterns.

Cloud deployments shall undergo security architecture review covering:

Identity → Network → Data → Workloads → Logging → Resilience → Compliance

Cloud resources shall not be deployed outside approved governance and security controls.

6. DETECT — Identify Security Events

The organization shall maintain centralized security visibility capable of proactively detecting suspicious activities and behavior anomalies across all cloud and on-premises environments, eliminating detection lacunae.

6.1 Centralized Monitoring

All multi-cloud security telemetry must stream in real time into Microsoft Sentinel (SIEM/SOAR/UBA) for predictive behavioral hunting. Telemetry ingestion must cover:

- **Authentication & Privileged Access**: All sign-ins, contextual access denials, and JIT/PAM session logs.
- **Infrastructure & Network Activity**: Micro-segmentation firewall logs, NGFW metrics, and ZTNA connection flows.
- **Workloads & Control-Planes**: Live endpoint health (EDR/MDM) and native audit trails across **AWS and Azure**.
- **Data & Configuration Changes**: Unauthorized access to client PII, security appliance alerts, and administrative configuration drifts.

6.1.1 Log Integrity & Compliance

- **Tamper Protection**: Logs must be encrypted, hashed, and stored in append-only, write-once-read-many (WORM) repositories to prevent unauthorized modification.
- **Regulatory Retention**: Data retention must satisfy audit-ready compliance for FINMA operational resilience, Swiss nFADP / GDPR data custody, and DORA event reconstruction frameworks.

6.3 Automated Detection & Response

The organization shall enforce automated **SOAR** capabilities within Microsoft Sentinel to reduce adversary dwell time from months to seconds and eliminate downstream breach costs.

6.3.1 The Automated Pipeline

Repeatable workflows with acceptable operational risk must follow this automated sequence:

Alert→Enrichment → Correlation →Prioritization → Escalation →Containment workflow

6.3.2 Execution Mandates

- Autonomous Containment: Cloud anomalies must instantly trigger AWS SSM, AWS Lambda, and Ansible playbooks to dynamically isolate compromised nodes and stop lateral ransomware movement.
- Immediate Escalation: High-severity alerts must immediately escalate per the Incident Response Plan to protect core financial transaction engines.
- Regulatory Validation: This automated loop enforces the recovery metrics (RTO/RPO) required by FINMA and DORA.

7. RESPOND — Contain and Manage Incidents

The organization shall maintain a documented and tested Incident Response Plan tailored to its hybrid multi-cloud infrastructure (AWS and Azure). All security incidents must follow this standardized lifecycle:

Preparation → Detection/Analysis → Containment → Eradication → Recovery → Lessons Learned

7.1 Incident Classification

Incidents shall be classified according to severity and business impact.

7.1 Incident Classification & Impact Mapping

Incidents shall be classified by severity to meet FINMA and DORA operational resilience criteria:

- **P1 / Critical**: Major compromise or disruption to core financial transaction engines and trading pipelines.
- **P2 / High**: Significant security compromise targeting sensitive data repositories or client PII.
- **P3 / Medium**: Contained multi-cloud security incident restricted within a single isolated trust zone.
- **P4 / Low**: Minor security event with no operational degradation or data exfiltration.

7.2 Responsibilities

- **SOC & Incident Response (IR) Teams:** The SOC performs initial detection and triage via Microsoft Sentinel. IR teams coordinate multi-cloud investigation, containment, and eradication.
- **Lead Security Architect:** Formally provides architecture-level guidance when incidents reveal legacy infrastructure vulnerabilities, executing the NIST SP 800-207 Zero Trust transformation strategy.
- **Executive & Legal Stakeholders:** Business leadership, Legal, Compliance, Privacy, and Communications shall be engaged immediately for P1/P2 events to manage regulatory reporting timelines under GDPR / Swiss nFADP.

7.3 Containment

Containment actions must execute via the Sentinel-to-Ansible SOAR loop within seconds to restrict the blast radius:

- **Identity & Session Controls**: Disabling compromised accounts and revoking active credentials/tokens.
- **Infrastructure Controls**: Isolating endpoints via EDR, blocking malicious traffic, and restricting network segments.
- **Workload Controls**: Suspending affected cloud workloads and activating alternative services via cross-cloud redundancy.
- **Forensic Preservation**: Multi-cloud evidence must be preserved in immutable, write-once-read-many (WORM) logs according to forensic and legal requirements.

7.4 Post-Incident Review

Material incidents must undergo formal lessons-learned analysis to optimize the corporate risk Company X shall determine:

What happened? → Why? → Which controls failed? → What was the business impact? → What must change?

Findings shall feed directly back into the risk register, security architecture patterns, and the automated orchestration playbooks.

8. RECOVER — Restore & Strengthen Operations

Recovery capabilities shall eliminate single points of failure, ensuring seamless restoration of critical business services within approved **FINMA** and **DORA** compliance metrics.

8.1 Business Impact Analysis & Metrics

To eliminate technical vulnerability and protect high-velocity transaction engines, all multi-cloud assets must map to a strict Business Impact Analysis (BIA) covering:

- **Criticality & Impact**: Business criticality, maximum tolerable disruption, and infrastructure dependencies.
- **Recovery Metrics**: Formal enforcement of aggressive **RTO** (Recovery Time Objective) and **RPO** (Recovery Point Objective) targets.
- **Priority & Automation**: Prioritized recovery ranking executed via automated cross-cloud redundancy (**AWS and** Azure), using AWS SSM**,** Lambda**, and** Ansible for instant backup synchronization and uninterrupted financial operations.

8.2 Backup

Critical data shall be backed up according to its designated RPO to protect revenue streams and preserve institutional profitability.

- **Protection & Isolation:** Backups must be encrypted (at rest and in transit), protected via strict separation of duties, and logically or physically isolated across the dual-provider (AWS and Azure) fabric to block ransomware propagation and eliminate single points of failure.
- **Monitoring & Testing:** Backup synchronization must be continuously monitored within Microsoft Sentinel. Automated restoration playbooks must be periodically tested to guarantee uninterrupted financial transactions and maintain strict FINMA and DORA compliance.

8.3 Disaster Recovery

Critical workloads shall utilize cloud-interoperable recovery architectures proportionate to their business impact to guarantee uninterrupted global financial transactions.

- **Failover Architecture**: High availability must be engineered via cross-cloud redundancy across the dual-provider fabric:

Primary Cloud Region AWS/Azure → Continuous Replication/Backup → Secondary Region Azure/AWS → Automated Failover

- **Target Metrics:** Critical services requiring rapid recovery shall target an RTO < 4 hours as justified by the BIA and approved business requirements, minimizing post-breach downtime and revenue shock.
- **Compliance Validation:** The failover pipeline must be orchestrated autonomously via AWS SSM, Lambda, and Ansible playbooks to satisfy FINMA business continuity and DORA operational resilience mandates**.**

8.4 Recovery Testing

Disaster Recovery (DR) capabilities shall be tested at least **annually**, and more frequently for critical services where required by **FINMA** and **DORA** mandates.

- **Validation Pipeline**: DR testing must rigorously validate the end-to-end recovery chain:

Back Up integrity

- **Backup integrity → Restoration → Application availability → Data consistency → RTO/RPO achievement**

- **Continuous Improvement:** Failed recovery tests shall immediately generate tracked corrective actions, which must feed directly back into the corporate risk register and security architecture patterns.
- **Automation Loop:** Testing workflows must utilize AWS SSM, Lambda, and Ansible playbooks to measure and guarantee the RTO < 4 hours metric during a simulated multi-cloud disruption.

9. Security Architecture Governance

All material technology initiatives shall undergo a formal architecture review before production deployment to eliminate technical vulnerabilities and ensure continuous FINMA and DORA compliance.

9.1 Review Lifecycle

The architecture authority, led by the Sr Security Architect, shall assess and document every initiative through this structured pipeline:

Business requirement → Risk → Architecture → Security controls → Residual risk → Approval

9.2 Deviations & Risk Acceptance

Significant deviations from the approved security architecture shall require a documented exception and formal risk acceptance. Exceptions must be logged in the corporate risk register, mapped against Swiss nFADP / GDPR liabilities, and subjected to a defined lifecycle review.

9.3 Reusable Security Patterns

The architecture function shall maintain cloud-agnostic, reusable security patterns across the dual-provider (AWS and Azure) fabric covering:

- **Identity & Access:** Centralized IAM, context-aware MFA, and Just-In-Time (JIT) privileged access.
- **Infrastructure & Data:** Micro-segmentation, zero trust network connectivity, and lifecycle encryption.
- **Operations & Resilience:** Continuous logging to Microsoft Sentinel, workload protection, isolated backups, and automated disaster recovery failover.

10. Metrics & Evidence

Security performance shall be measured and reported.

The program should monitor metrics such as:

KPI/KRI	Target
Privileged accounts protected by MFA/PAM	**100%**

Critical workloads assessed for encryption	**100%**
Critical assets with identified owners	**100%**
Critical vulnerabilities remediated within SLA	**≥95%**
Critical workloads with documented RTO/RPO	**100%**
Critical workloads covered by centralized logging	**100%**
Annual DR tests completed	**100% of critical services**
High-risk architecture findings with treatment plans	**100%**
Security awareness completion	**≥95%**
Architecture exceptions formally documented	**100%**

Metrics shall be reviewed periodically by security leadership and used to prioritize remediation and investment.

11. Exceptions

Exceptions to this policy shall:

1. identify the requirement that cannot be satisfied.
2. document the business justification.
3. identify the associated cybersecurity risk.
4. define compensating controls.
5. identify a risk owner.
6. receive formal approval.
7. contain an expiration/review date.

Permanent undocumented exceptions are prohibited.

12. Compliance

Failure to comply with this policy may expose the organization to security, operational, contractual and regulatory risk.

Compliance shall be validated through: **Architecture reviews → Configuration assessments → Vulnerability assessments → Access reviews → Penetration testing → Audits → Control testing → Risk assessments**. Findings shall be documented and assigned to accountable owners for remediation.

13. Policy Maintenance

This policy shall be reviewed annually at least annually by a cyber risk committee monthly or quarterly

Members:

- CIO
- CISO
- CRO
- Legal
- Privacy
- Enterprise Architect
- Business Leadership

Security Architecture Review Board

Responsible for:

- approving designs
- reviewing deviations
- assessing residual risk
- approving cloud patterns

14. Supporting Standards & Procedures

This enterprise policy should sit above several more technical documents:

Information Security & Cyber Resilience Policy
→ IAM & Access Control Standard
→ Privileged Access Management Standard
→ Cloud Security Standard
→ Network Security & Segmentation Standard
→ Encryption & Key Management Standard
→ Vulnerability Management Standard
→ Logging & Monitoring Standard
→ Incident Response Plan
→ Business Continuity Policy
→ Disaster Recovery Standard
→ Third-Party Security Standard
→ Security Awareness Standard

NIST Mapping:

Policy Area	NIST Function	Company X Evidence
Asset/risk/vulnerability assessment	**IDENTIFY**	Threat modelling, vulnerabili assessment
IAM/MFA/PAM/RBAC/ABAC	**PROTECT**	Zero Trust / Least Privilege
NGFW/IDS/IPS/SASE/segmentation	**PROTECT**	Network/perimeter architecture

Encryption/DLP	**PROTECT**	Data-security architecture
SIEM/UBA	**DETECT**	Central monitoring
SOAR/SOC/IR	**RESPOND**	Detection, escalation, remediation
Backup/failover/DR	**RECOVER**	Primary → secondary region
Auditing/risk/compliance	**Cross-functional governance**	Security reviews and documentation